INFORME DE EVALUACIÓN DE SEGURIDAD

Evaluación de seguridad de la aplicación Turnero — Software Seguro

20 OCTUBRE DE 2026

CONFIDENCIAL - REPORTE DE SEGURIDAD E INFORMACIÓN DE AUDITORÍA

Índice / Tabla de Contenidos

1. Resumen Ejecutivo y Ficha Técnica ..... Pág. 3

2. Metodología de Evaluación y Estándares Aplicados ..... Pág. 4

2.1 Marcos utilizados ..... Pág. 4

2.2 Escala de severidad y prioridad ..... Pág. 4

3. Métricas y Distribución Estadísticas de Hallazgos ..... Pág. 5

4. Gráficos de Distribución (Score (CVSS)) ..... Pág. 6

5. Gráficos de Distribución (Estado del Ticket) ..... Pág. 7

6. Alcance técnico y componentes evaluados ..... Pág. 8

7. Hallazgos identificados ..... Pág. 9

8. Listado Resumido y Detalle de Hallazgos (1 tickets) ..... Pág. 10

9. Conclusiones y plan de remediación recomendado ..... Pág. 11

Resumen Ejecutivo y Ficha Técnica

Durante la evaluación autorizada del laboratorio Turnero se identificó una falla de control de acceso en la API de gestión de turnos. Con una cuenta autenticada fue posible consultar y eliminar turnos de otros usuarios al modificar identificadores en las solicitudes. La información visible incluía clínica, fecha, hora, especialista e identificadores de usuario. El hallazgo tiene severidad Media y un puntaje CVSS 3.0 de 6.3. Se recomienda validar en el servidor que cada usuario solo pueda acceder y realizar acciones sobre los turnos que está autorizado a gestionar.

Parámetro / Campo Detalle de la Evaluación	
Tipo de Evaluación	Prueba de seguridad web autenticada
Estándar Principal	OWASP ASVS 4.0.3, V4.2.1
Período de Pruebas	20 de Octubre de 2026
Entorno de Evaluación	Laboratorio educativo Software Seguro - Turnero
Clasificación del Documento	**ESTRICTAMENTE CONFIDENCIAL – USO ACADÉMICO**

Metodología de Evaluación y Estándares Aplicados

La evaluación se realizó de forma manual sobre el laboratorio Turnero, utilizando una cuenta autenticada y las herramientas de desarrollo del navegador para observar las solicitudes de red. Se revisaron las operaciones de consulta y eliminación de turn os y se modificaron identificadores para comprobar si el servidor validaba los permisos sobre cada registro.

Técnicas utilizadas: Se realizaron pruebas manuales de seguridad web sobre la aplicación en ejecución, con una cuenta aute nticada. Se inspeccionaron y modificaron solicitudes HTTP para evaluar los controles de autorización. No se efectuaron anális is SAST ni escaneos DAST automatizados.

Alcance de las pruebas: Aplicación web Turnero y su API de gestión de turnos, dentro del laboratorio Software Seguro.

2.1 Marcos utilizados

OWASP ASVS 4.0.3 — V4.2.1: referencia para comprobar la protección de datos y API frente a IDOR.

CVSS 3.0: utilizado para estimar la severidad del hallazgo según sus condiciones de explotación e impacto.

2.2 Escala de severidad y prioridad

Los hallazgos se clasifican utilizando CVSS versión 3.0. Para cada hallazgo se informa el puntaje, el nivel de severidad y el vect or CVSS correspondiente.

El hallazgo de Turnero se clasificó como **Media (6.3)**.

Escala			
Baja (0.1 – 3.9)	**Media (4.0 – 6.9)**	**Alta (7.0 – 8.9)**	**Crítica (9.0 – 10.0)**

Métricas y Distribución Estadísticas de Hallazgos

Durante la evaluación se registró un hallazgo de seguridad. Fue clasificado como Medio, con un puntaje CVSS 3.1 de 6.3.



Distribución de los hallazgos según su puntaje CVSS. La gráfica permite comparar su severidad e identificar cuáles requieren mayor atención

Distribución por Estado del Ticket



CATEGORÍA	CANT.	%
Validado	1	100.0%

Total contabilizado: 1

La gráfica muestra la proporción de hallazgos según su estado actual. Esta información permite conocer el avance del seguimiento y de las tareas de corrección

Alcance técnico y componentes evaluados

La evaluación abarcó la aplicación web Turnero y las operaciones de consulta y eliminación de turnos mediante su API. Se revisó el control de acceso horizontal desde una sesión autenticada, modificando identificadores de usuario y de turno. Se comprobó si era posible consultar información y eliminar turnos asociados a otros usuarios

- Autenticación y gestión de sesiones: Se utilizó una cuenta autenticada del laboratorio. No se evaluaron los controles de autenticación ni la gestión de sesiones.
- Control de acceso: Se modificaron identificadores para probar el acceso a turnos de otros usuarios. Se comprobó una falla BOLA/IDOR que permitió consultar y eliminar turnos ajenos.
- Validación de entradas: No evaluada.
- Comunicaciones y criptografía: No evaluadas.
- Manejo de errores y registro de eventos: No evaluados

Hallazgos identificados

A continuación se detalla el hallazgo identificado durante la evaluación, junto con su impacto, evidencia, prueba de concepto y recomendación de remediación.

HALLAZGO #1 Validado

Software Seguro v1.0.1

Plantilla: Plantilla
Ref ID: Turnero

TITULO

Acceso y eliminación no autorizados de turnos de otros usuarios

TIPO

Control de acceso roto (IDOR/BOLA)

SEVERIDAD

Media

DESCRIPCIÓN

La API permite consultar y eliminar turnos de otros usuarios al cambiar identificadores en las solicitudes. No verifica que los turnos pertenezcan al usuario autenticado. En las consultas se observaron la clínica, la fecha, la hora, el especialista y los identificadores de usuario.

SCORE

6.3 (CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L)

CHECK

✓ **V4.2.1** - Verifique que los datos confidenciales y las API están protegidos contra ataques de referencia insegura directa de objetos (IDOR)... como la visualización de los registros de todos o la eliminación de todos los registros.

IMPACTO

Un usuario autenticado puede ver datos de turnos de otras personas y eliminar algunos de esos turnos. Esto expone parcialmente información y afecta la integridad y disponibilidad de los turnos modificados o eliminados.

PRUEBA DE CONCEPTO (POC)

1. Iniciar sesión en el laboratorio con una cuenta habilitada.
2. Abrir las herramientas de desarrollador del navegador y observar las solicitudes de red al consultar turnos.
3. Cambiar el identificador de usuario en la solicitud de consulta, por ejemplo, en GET /api/101/appointments/.
4. Comprobar que la respuesta incluye turnos de otro usuario.
5. Enviar una solicitud DELETE para el identificador de uno de esos turnos, por ejemplo, DELETE /api/appointments/10.
6. Volver a consultar los turnos y comprobar que el turno eliminado ya no aparece.

RECOMENDACIÓN

Verificar en el servidor que cada turno consultado o eliminado pertenezca al usuario au
tenticado, o que este tenga autorización explícita para gestionarlo. No confiar únicame
nte en los identificadores enviados por el cliente.

Conclusiones y plan de remediación recomendado

En el laboratorio Turnero se identificó una falla BOLA/IDOR de severidad Media que permitió consultar y eliminar turnos perte necientes a otros usuarios. Se recomienda corregir el control de acceso en el servidor, verificando en cada operación que el u suario autenticado sea propietario del turno o tenga autorización explícita para gestionarlo. También se recomienda agregar pruebas que comprueben el aislamiento entre usuarios y realizar una nueva evaluación después de implementar la corrección .

Informe elaborado por: Gabriel Agustín, Bertero Jarchum.

Revisión: No Corresponde.